1. Enumeration of scanme.nmap.org

Objective

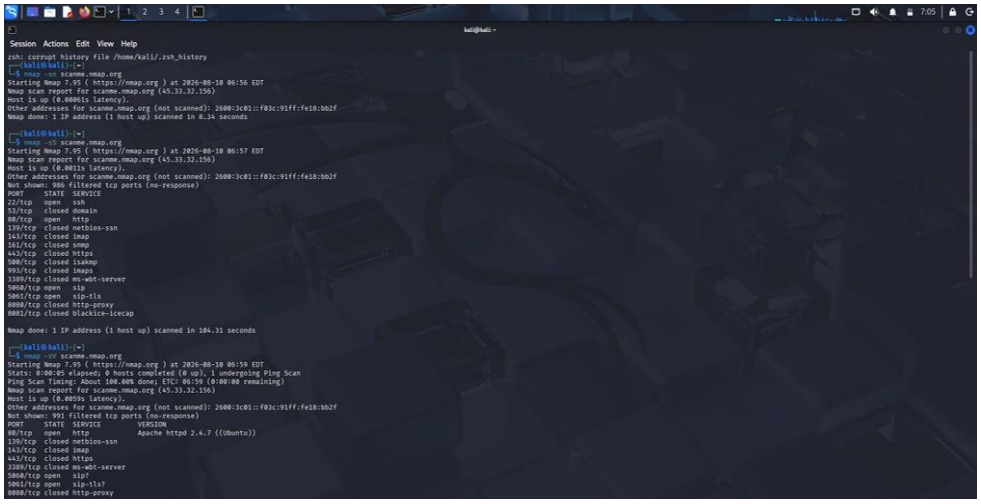
The objective is to perform an initial security assessment of the publicly accessible host scanme.nmap.org using Nmap and identify:

- Host availability
- Open TCP ports
- Running services

Step 1: Host Discovery

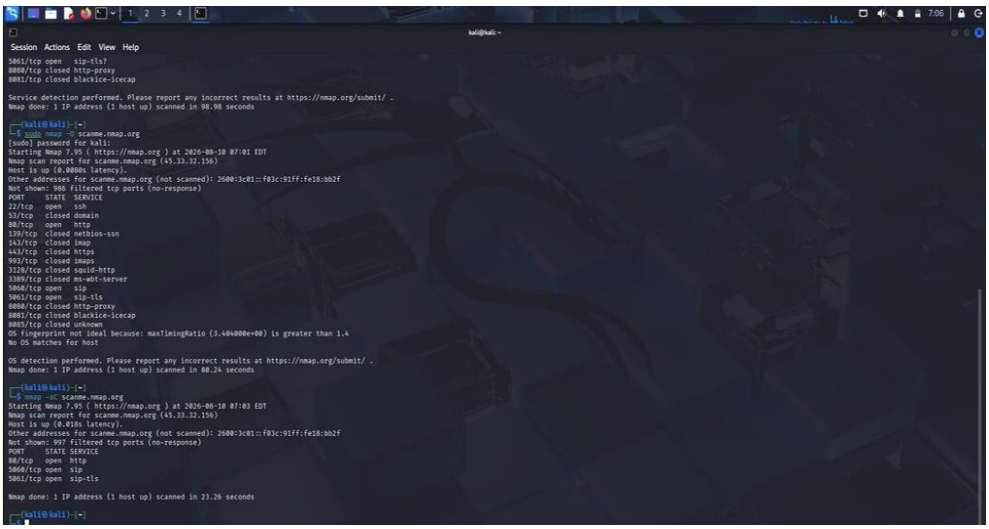
Command

nmap -sn scanme.nmap.org



Step 2: TCP Port Scanning

nmap -sT scanme.nmap.org



Step 3: Service Version Detection

nmap -sV scanme.nmap.org

The -sV option attempts to determine:

- Service name
- Application
- Version

Analysis

SSH may be required for legitimate remote administration. However, publicly exposing SSH increases the possibility of:

- Password-guessing attempts
- Credential attacks
- Exploitation of vulnerable SSH versions
- User enumeration depending on configuration

HTTP is normally required if the host provides a publicly accessible website.

Step 4: OS Fingerprinting

sudo nmap -O scanme.nmap.org

Or:

nmap -O -sV scanme.nmap.org

Step 5: Default Script Scanning

nmap -sC scanme.nmap.org

A combined scan can be performed as:

nmap -sC -sV -O scanme.nmap.org

For a broader TCP assessment:

nmap -p- -sC -sV scanme.nmap.org

-p- scans all TCP ports.

Recommendations

1. Disable unnecessary public services.

2. Restrict SSH using firewall rules.
3. Use SSH keys instead of passwords where possible.
4. Implement MFA for administrative access.
5. Keep operating systems and services patched.
6. Use HTTPS instead of unencrypted HTTP where applicable.
7. Monitor authentication logs.
8. Implement rate limiting and intrusion detection.
9. Minimize service-version disclosure.
10. Regularly perform vulnerability assessments.

Conclusion

Nmap enumeration provides valuable information about the host's externally visible attack surface. The discovered services should be compared with their business requirements, and services that are not required for public access should be disabled or restricted.

2. Enumeration of Metasploitable 2 — 192.168.56.101

Objective

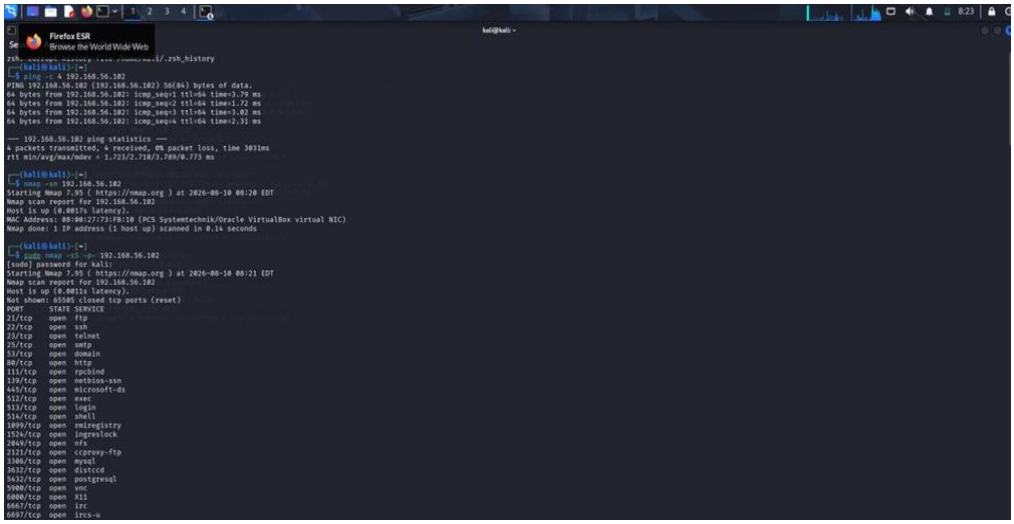
The purpose is to comprehensively enumerate the deliberately vulnerable Metasploitable 2 Linux server in an isolated laboratory.

Step 1: Host Discovery

nmap -sn 192.168.56.101

Step 2: Scan All TCP Ports

nmap -p- 192.168.56.101

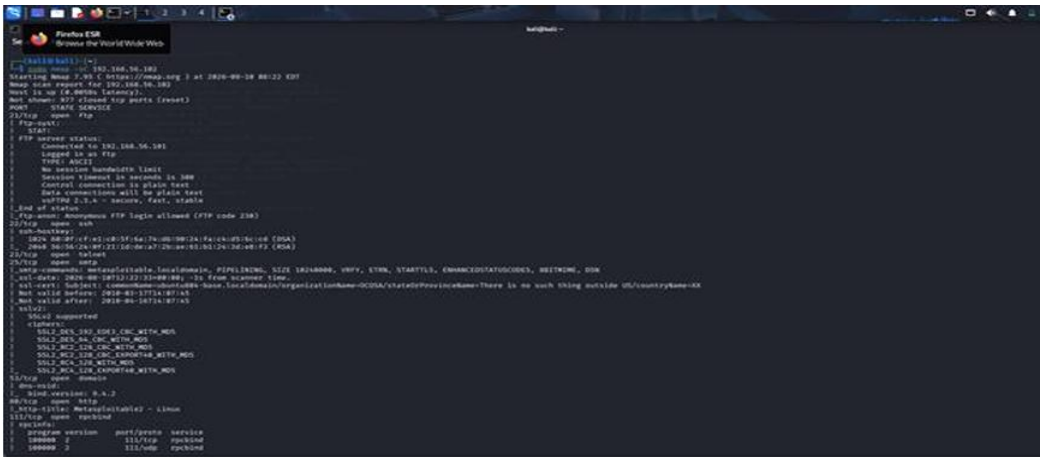


Step 3: Service Detection

nmap -sV -p- 192.168.56.101

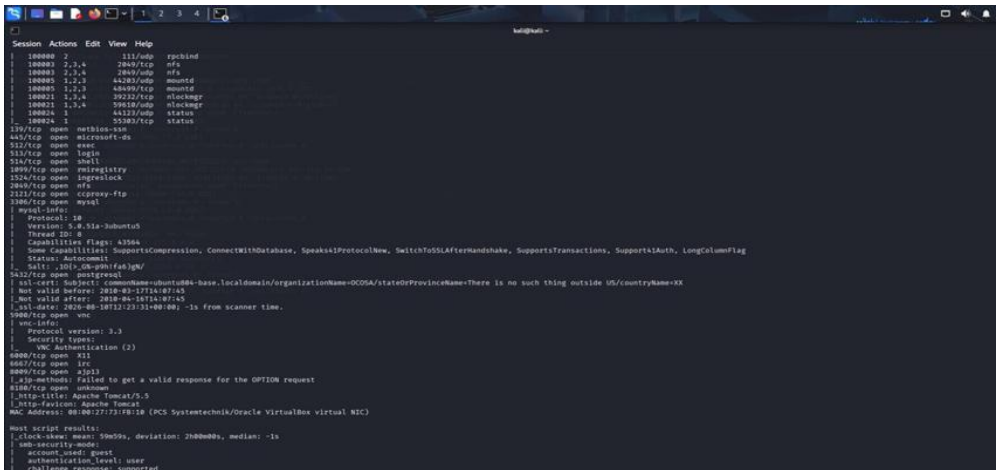
Step 4: OS Detection

sudo nmap -O 192.168.56.101



Step 5: Default NSE Scripts

nmap -sC -sV 192.168.56.101



SMB/NetBIOS — Ports 139/445

These services provide network file sharing and related functionality.

Potential risks include:

- Unauthorized file access
- Information disclosure
- Weak credentials
- Vulnerable SMB implementations

Risk: High.

Database Services

Examples include MySQL and PostgreSQL.

A database should generally not be directly accessible from untrusted networks.

Risk: High if externally accessible and weakly configured.

Risk Classification

High Risk

Services that may provide significant attack opportunities:

- Telnet
- Vulnerable FTP
- SMB
- Vulnerable HTTP applications
- Exposed databases
- Vulnerable RPC services

Medium Risk

- SSH
- SMTP
- DNS
- Other services requiring authentication/configuration review

Low Risk

A service can be classified as low risk when:

- It is necessary
- Properly configured
- Patched
- Restricted to trusted hosts

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:73:fb:10
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:57 errors:0 dropped:0 overruns:0 frame:0
          TX packets:72 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8714 (8.5 KB)  TX bytes:6464 (6.3 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

Recommendations

For a production Linux server:

1. Disable Telnet.
2. Restrict FTP or replace it with SFTP.
3. Patch all services.
4. Restrict database ports.
5. Disable unnecessary RPC services.

Conclusion

Metasploitable 2 intentionally exposes many vulnerable services. Nmap provides the reconnaissance required to map these services and prioritize potential attack vectors in a controlled penetration-testing environment.

3. Windows Workstation — 192.168.56.102

Objective

The objective is to identify active services on the Windows workstation and determine whether they follow the principle of least privilege.

Step 1: Host Discovery

nmap -sn 192.168.56.102

Step 2: TCP Port Scan

nmap -p- 192.168.56.102

Step 3: Service Detection

nmap -sV 192.168.56.102

Step 4: OS Detection

sudo nmap -O 192.168.56.102

Step 5: Windows/SMB Enumeration

nmap -p 135,139,445 --script smb-protocols 192.168.56.102

Additional SMB information:

nmap -p 445 --script smb2-security-mode,smb2-time 192.168.56.102

Step 6: Comprehensive Scan

sudo nmap -p- -sC -sV -O 192.168.56.102 -oN windows_scan.txt

Lateral Movement

Exposed SMB, RDP, and Windows remote-management services can become important after an attacker obtains valid credentials on another machine.

Unauthorized Access

Weak authentication combined with exposed remote-management services increases risk.

Hardening Recommendations

1. Disable unnecessary services

Unused SMB → Disable/restrict

Unused RDP → Disable

Unused WinRM → Disable

Unused RPC exposure → Restrict

2. Firewall

Allow management services only from trusted administrative systems.

3. Strong Authentication

Use:

- Strong passwords
- MFA where supported
- Account lockout/rate limiting

4. Patch Management

Regularly update:

- Windows
- SMB components
- RDP
- Management services
- Installed applications

5. Network Segmentation

Place administrative services on a restricted management network.

Conclusion

Nmap enumeration helps determine whether a Windows workstation exposes services beyond what is required. Reducing unnecessary services and restricting management protocols significantly decreases the attack surface.

4. OWASP Juice Shop Server — 192.168.56.103

Objective

The objective is to map the network exposure of the Juice Shop server before conducting a full penetration test.

OWASP Juice Shop is intentionally designed as a vulnerable web application for security training.

Step 1: Host Discovery

nmap -sn 192.168.56.103

Step 2: Port Scanning

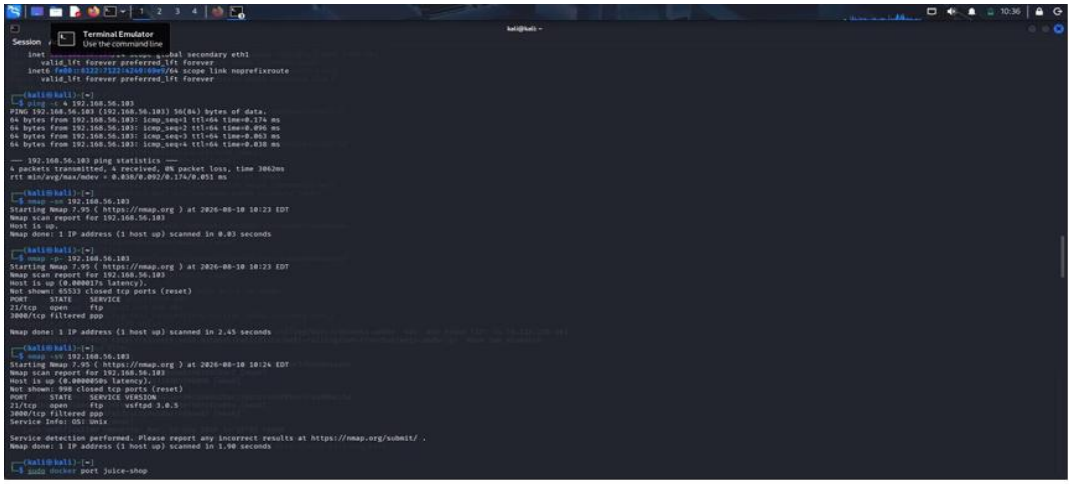
nmap -p- 192.168.56.103

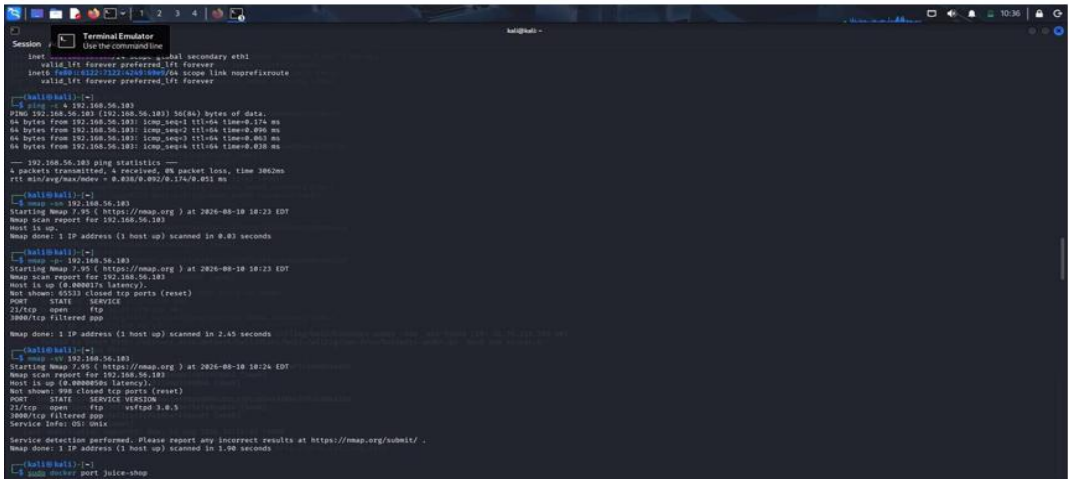
Step 3: Service Detection

nmap -sV 192.168.56.10

Step 4: OS Fingerprinting

sudo nmap -O 192.168.56.103





Step 5: Default Scripts

nmap -sC -sV 192.168.56.103

Step 6: Web Service Identification

If port 80 is open:

nmap -p 80 --script http-title,http-headers 192.168.56.103

Web Application Exposure

A publicly accessible web service increases the attack surface because attackers can test:

- Authentication
- Authorization
- Input validation
- File handling
- Database interaction

- sudo nmap -sT -O 192.168.56.103
- sudo nmap -sT -A 192.168.56.103
- curl -I http://192.168.56.103:3000

- Error handling

Juice Shop is intentionally vulnerable, so it is especially suitable for penetration-testing training.

Recommendations

1. Expose only required web ports.
2. Disable unnecessary services.
3. Restrict administrative interfaces.
4. Use HTTPS.

Conclusion

Nmap provides the network-level view required before application penetration testing. Understanding the exposed ports, services, and supporting infrastructure allows testers to prioritize web, API, authentication, and configuration testing.

5. Gateway — 192.168.56.1

Objective

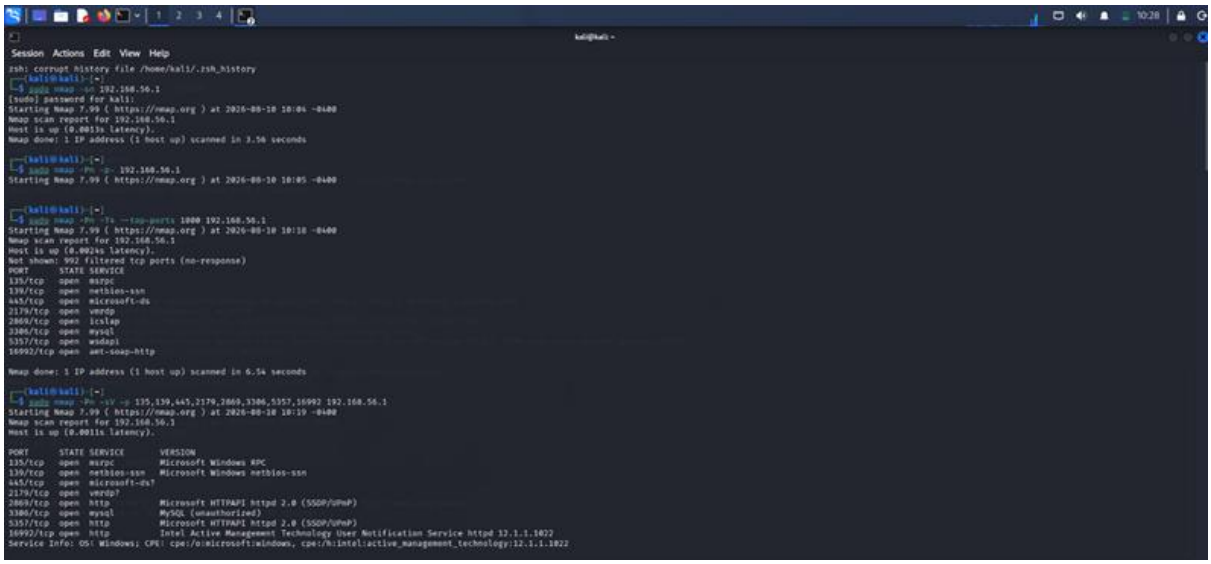
The objective is to identify exposed network-management services on the laboratory gateway and determine whether they are necessary.

Step 1: Host Discovery

nmap -sn 192.168.56.

Step 2: TCP Port Scan

nmap -p- 192.168.56.



Step 3: Service Detection

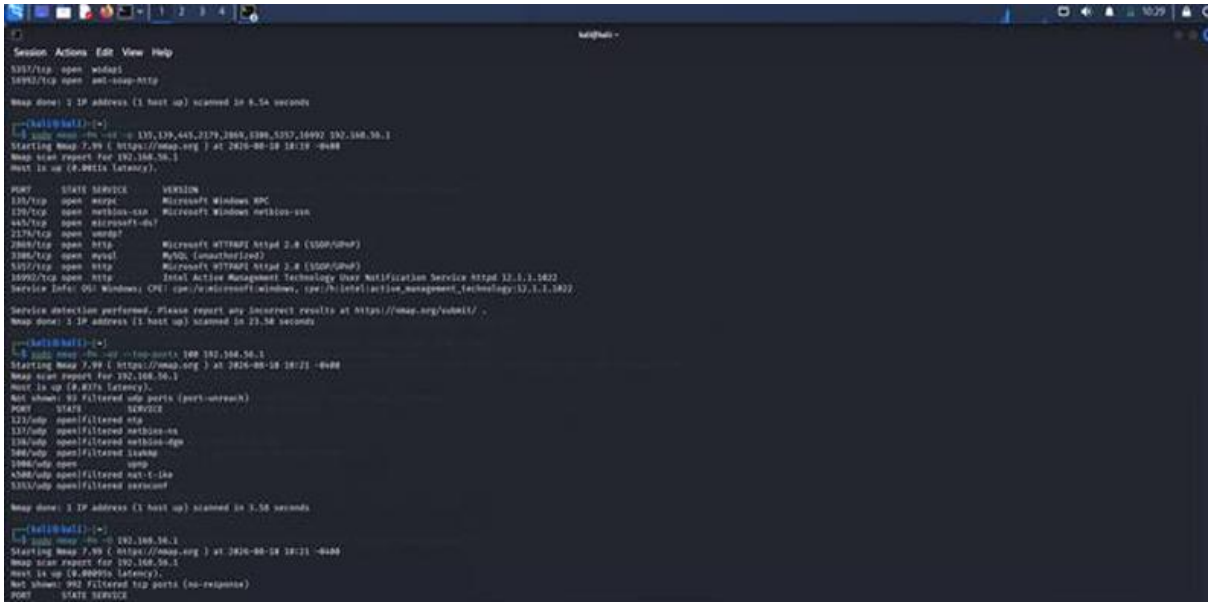
nmap -sV 192.168.56.1

Step 4: OS Fingerprinting

sudo nmap -O 192.168.56.

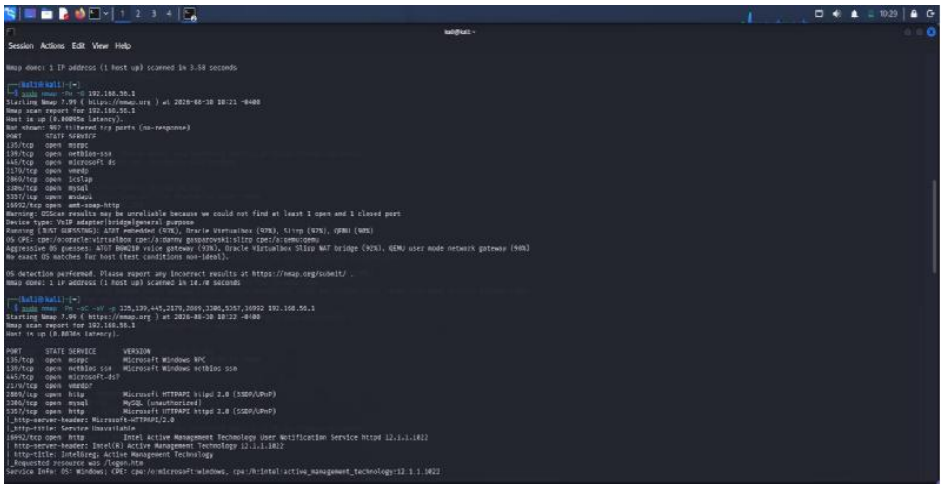
Step 5: Default Script Scan

nmap -sC -sV 192.168.56.1



Step 6: Management-Service Scan

nmap -p 22,23,80,443,161,162 192.168.56.1



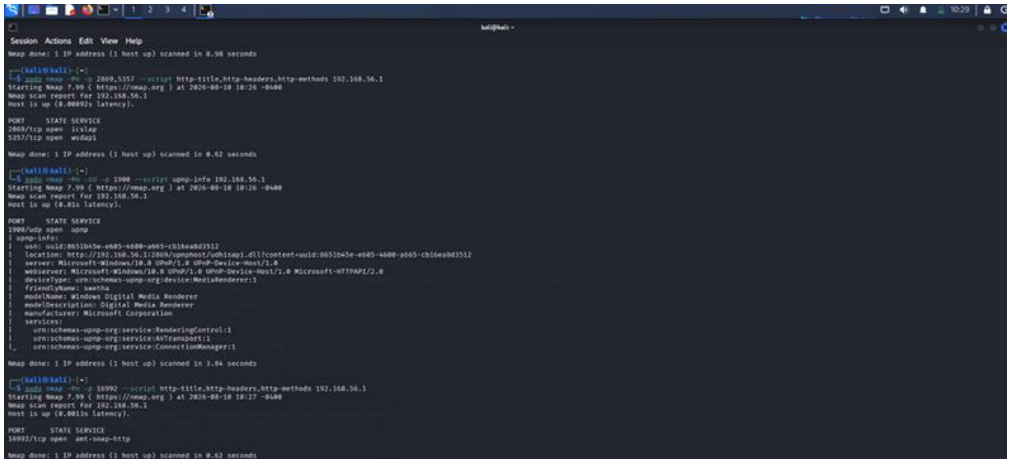
Management Interface Analysis

SSH — Port 22

SSH provides secure remote administration.

Security concerns

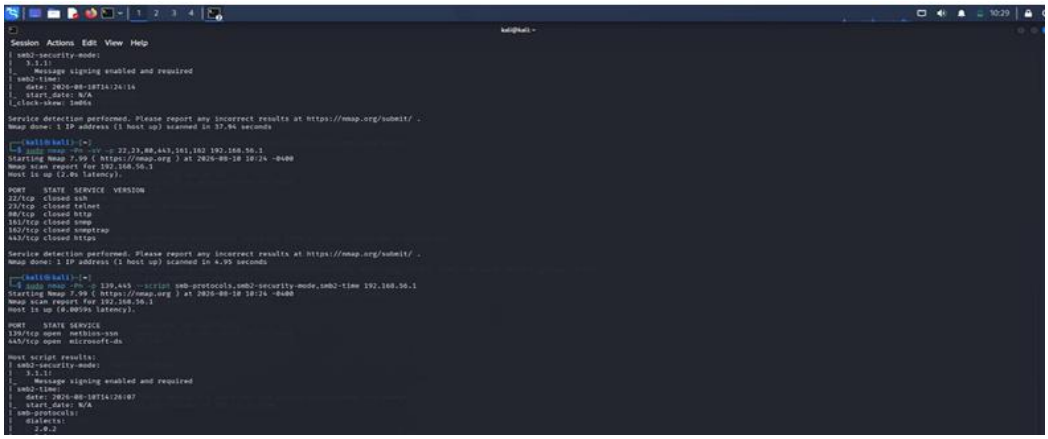
- Weak passwords
- Exposed authentication service
- Vulnerable SSH implementation
- Excessive administrative access



Recommendation

- Use key-based authentication.
- Disable password authentication where practical.
- Restrict SSH to management hosts.
- Use MFA where supported.

Risk: Medium if restricted; High if unnecessarily exposed.



Telnet — Port 23

Telnet is an insecure remote-management protocol.

Authentication information can be transmitted without modern encryption.

Recommendation

Disable Telnet.

Use:

SSH instead of Telnet

Risk: High.

HTTP — Port 80

HTTP may provide a router/gateway management interface.

The major concern is that management credentials and administrative information may be exposed if authentication is not protected properly.

Recommendation

- Disable HTTP management if unnecessary.
- Redirect or replace with HTTPS where supported.
- Restrict access to the management network.

Risk: High if it exposes administration without adequate protection.

HTTPS — Port 443

HTTPS is preferable to HTTP because it provides encrypted communication.

However, security still depends on:

- Strong authentication
- Valid TLS configuration
- Current software
- Access restrictions
- No default credentials

Risk: Medium when properly configured; High if vulnerable or broadly exposed.

SNMP — Port 161

SNMP is used for network monitoring and management.

Older SNMP configurations may use weak community strings.

Potential information exposure includes:

- Device information
- Interface information
- Network configuration
- System information

Recommendation

- Prefer SNMPv3.
- Disable SNMP if not required.
- Restrict SNMP access to monitoring servers.
- Use strong authentication/privacy settings.

Risk: Medium/High depending on configuration.

If unnecessary management services are exposed, attackers gain additional opportunities for reconnaissance and unauthorized access.

How Attackers Could Abuse Management Services

2. Credential Attacks

Exposed SSH or Telnet may attract authentication attacks.

3. Information Gathering

SNMP may reveal useful network information if improperly configured.

4. Management Interface Attacks

A vulnerable HTTP/HTTPS management interface could potentially expose administrative functionality.

5. Network Compromise

Compromising a gateway is particularly serious because it can provide a privileged position within the network

Security Controls

1. Disable Unnecessary Services

If a service has no business requirement:

Disable it.

2. Restrict Management Access

Management interfaces should be accessible only from trusted administrator systems.

3. Disable Telnet

Replace:

Telnet → SSH

4. Secure SSH

Use:

- Strong credentials
- SSH keys
- MFA
- IP restrictions
- Account monitoring

5. Secure SNMP

Prefer:

SNMPv3

over older versions when supported.

6. Secure Web Management

Use:

HTTPS

instead of HTTP.

Change default credentials immediately

7. Network Segmentation

Separate:

- User network
- Server network
- Management network
- Guest network

8. Logging and Monitoring

Monitor:

- SSH login attempts
- Administrative logins
- Configuration changes
- SNMP access
- Web management access

Overall Conclusion

Nmap enumeration is an important first phase of an authorized penetration test because it establishes the target's externally visible attack surface.